

# SIMATS ENGINEERING

## ASSESSMENT TOOL 3

**COURSE NAME: Ethical Hacking COURSE CODE: ITA14**

### **COURSE OUTCOME COVERED**

**CO2:** Foot printing Tools : Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

*Assessment Tool Weightage: 30%*

**Duration: 90 min Total Marks: 50 Scenario-Based Assessment**

### **Topic 1: Footprinting Tools – Conducting Competitive Intelligence**

#### **Q1. (L3 – Apply) – 15 Marks**

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

**Task:** Apply suitable footprinting tools to identify the company's:

- domain registration details,
- employee email addresses,
- technology stack,
- and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

#### **Introduction**

Footprinting is the process of collecting publicly available information about an organization. In this assessment, passive tools such as **WHOIS, theHarvester, Wappalyzer, and crt.sh** are used to identify domain details, email addresses, technologies, and subdomains without directly interacting with the company's servers.

#### **Commands:**

##### **1. Domain Registration – WHOIS**

- Command:

whois <domain-name>

- Explanation:

- Shows domain and registrar details.

- Provides registration dates and name servers.
- Helps understand domain infrastructure.

## 2. Email Addresses – theHarvester

- Command:

```
theHarvester -d <domain-name> -b bing
```

- Explanation:

- Finds publicly available email addresses.
- May identify hosts and subdomains.
- Shows the organization's public communication structure.

## 3. Technology Stack – Wappalyzer

- Method: Check the organization's public website using Wappalyzer.

- Explanation:

- Identifies web technologies, frameworks, and CMS.
- Helps understand the technology environment.

## 4. Subdomains – theHarvester / crt.sh

- Command:

```
theHarvester -d <domain-name> -b bing
```

- Explanation:

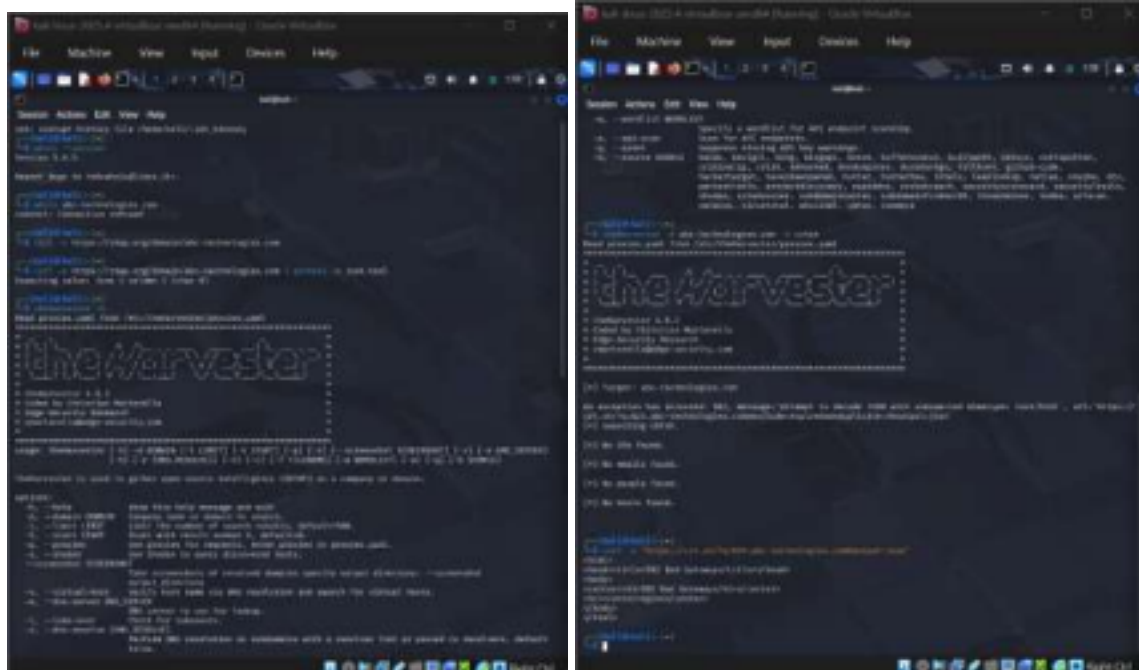
- Identifies publicly exposed subdomains and hosts.
- Helps understand public-facing infrastructure.

## Competitive Intelligence

- **WHOIS:** Domain information.
- **theHarvester:** Emails, hosts, and subdomains.
- **Wappalyzer:** Technology stack.
- **crt.sh:** Certificate and subdomain information.
- **Overall:** These tools provide an overview of the organization's public digital presence.

## Conclusion

Passive footprinting helps collect useful information without directly interacting with the organization's servers. The gathered domain, email, technology, and subdomain information can help understand the organization's public presence and identify areas where information exposure can be reduced.



## Topic 2: DNS Zone Transfers

### Q2. (L3 – Apply) – 15 Marks

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

**Task:** Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

#### Introduction

A DNS zone transfer (AXFR) is used to copy DNS records between authorized DNS servers. If a DNS server allows unauthorized zone transfers, it may expose information about the organization's hosts, mail servers, and subdomains.

#### Commands:

##### • Verify DNS Zone Transfer

Command:

```
dig @<DNS-Server-IP> <domain-name> AXFR
```

Explanation:

- dig is used for DNS queries.
- @<DNS-Server-IP> specifies the DNS server.
- <domain-name> specifies the target domain.
- AXFR requests a full DNS zone transfer.

#### Observation

- Successful transfer: DNS records are displayed, indicating that AXFR is permitted.
- Failed transfer: The server refuses or denies the request, indicating that unauthorized transfer is restricted.

## Information Obtained

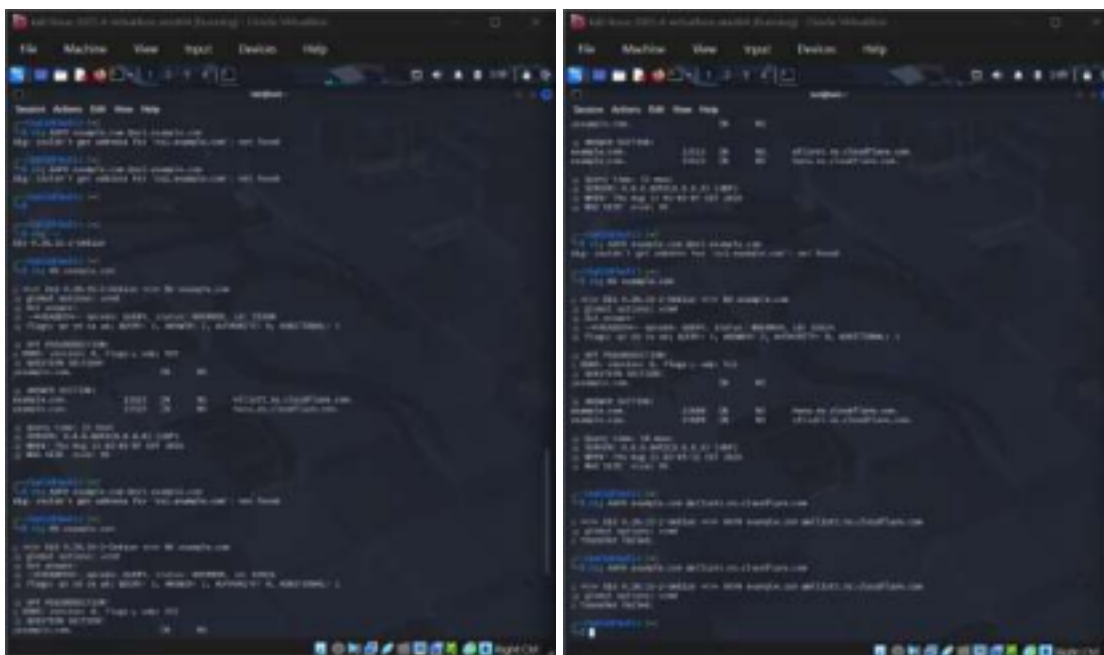
If the transfer succeeds, the results may reveal:

- Internal hosts – Hostnames and IP addresses of systems.
- Mail servers – MX records identify mail servers.
- Subdomains – Records can reveal different subdomains.
- DNS structure – A complete view of available DNS records may be exposed.

## Reconnaissance Use

- Identify hosts: Attackers can identify systems and their IP addresses.
  - Find mail servers: MX records reveal mail-server infrastructure.
  - Discover subdomains: Subdomains can reveal additional services and applications.
  - Map infrastructure: Multiple DNS records can help build a picture of the organization's network.
  - Plan further attacks: The information can be used to identify systems that require security assessment.
- Conclusion**

The dig AXFR query provides a simple way to verify whether DNS zone transfers are improperly permitted. An unauthorized successful transfer can expose valuable DNS information and make reconnaissance easier. DNS administrators should restrict zone transfers to authorized secondary DNS servers and use appropriate access controls and authentication.



## Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures

### Q3. (L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

## Introduction

Social engineering is a technique that manipulates people into revealing sensitive information or performing unsafe actions. In this scenario, employees receive a fake IT email asking them to verify their login credentials through a link.

### Type of Attack

#### Attack: Phishing

More specifically, it is a **credential-phishing attack** because the attacker attempts to trick employees into providing their username and password through a fraudulent link.

#### Warning Signs

- Email claims to be from the IT department.
- Uses **urgent security-update** language.
- Requests login credentials.
- Provides a suspicious link.
- Creates pressure to respond quickly.

### Countermeasures

- **Do not click the link** in suspicious emails.
- **Verify the sender** and email address carefully.
- **Check the URL** before opening any link.
- **Contact the IT department directly** using an official contact method.
- **Never share passwords** through email or unknown websites.
- **Report suspicious emails** to the security/IT team.
- **Enable MFA** on organizational accounts.
- **Delete or quarantine** confirmed phishing emails.

### How These Actions Prevent Credential Theft

- Avoiding suspicious links prevents users from reaching fake login pages.
- Checking the sender helps identify impersonation.
- Verifying the URL helps detect fraudulent websites.
- Contacting IT confirms whether the security request is genuine.
- Not sharing passwords prevents attackers from obtaining credentials.
- MFA provides an additional layer of protection even if a password is compromised.

### Conclusion

The scenario represents a **phishing-based credential theft attack**. Employees can reduce the risk by avoiding suspicious links, verifying requests, protecting passwords, reporting phishing emails, and using MFA. These actions prevent attackers from obtaining login credentials and reduce the success of social engineering attacks.

## Scenario-Based

### *Code of Conduct:*

*I G. NITHYA SREE certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

*I understand that any violation of academic integrity rules will result in disciplinary action.*

### *Signature of the student:*

## RUBRICS FOR CALCULATION

### Scenario Based Assessment

| Criteria                     | Weightage (%) | Level 4<br>(Exemplary)                                                    | Level 3<br>(Proficient)                            | Level 2<br>(Developing)                           | Level 1<br>(Beginning)                            |
|------------------------------|---------------|---------------------------------------------------------------------------|----------------------------------------------------|---------------------------------------------------|---------------------------------------------------|
| Understanding of Scenario    | 20%           | Demonstrates clear and complete understanding of the scenario and context | Shows good understanding with minor gaps           | Partial understanding; misses key aspects         | Misinterprets or fails to understand the scenario |
| Identification of Key Issues | 20%           | Accurately identifies all relevant issues and factors involved            | Identifies most key issues with minor omissions    | Identifies limited issues; some irrelevant points | Unable to identify key issues                     |
| Application of Concepts      | 25%           | Applies appropriate concepts effectively to address the scenario          | Applies concepts with minor errors                 | Limited or partially correct application          | Unable to apply relevant concepts                 |
| Decision Making              | 20%           | Makes well reasoned, logical decisions with strong rationale              | Makes reasonable decisions with some justification | Makes weak decisions with limited justification   | No clear decisions made or rationale provided     |
| Clarity of Response          | 15%           | Response is clear, structured, and logically presented                    | Generally clear with minor issues                  | Somewhat unclear or poorly structured             | Disorganized and difficult to understand          |